

Relatório Forense

Potencial exploração IDOR no endpoint de busca de invoices

61.961	10.181	10.173
requisições automatizadas	invoices no cluster	invoices com HTTP 200

CONCLUSÃO	Alta confiança de exploração automatizada compatível com IDOR; média confiança de divulgação de PII.
-----------	--

Janela observada: 2025-10-01 a 2025-12-31
Data da análise: 2026-08-21
Versão pública sanitizada

1. Sumário executivo

Foram analisados 4.478.619 registros do endpoint `/invoices/search`. Cinco IPs exclusivamente automatizados, operando com `crawler4j`, `Scrapy` e `wget`, fizeram 61.961 requisições com apenas quatro tokens e consultaram 10.181 invoices distintos. Embora representem apenas 1,38% do tráfego, essas origens tocaram 99,49% dos 10.233 invoices presentes nos logs. O padrão é incompatível com uso humano normal e sustenta alta confiança de exploração automatizada da vulnerabilidade IDOR.

O cluster recebeu 44.868 respostas HTTP 200 associadas a 10.173 invoices, ou 99,41% do universo observado. Esse é o conjunto conservador de potencial exposição para investigação de impacto. O status não prova, sozinho, que o corpo continha PII ou que houve acesso cross-account: faltam `response body/bytes`, `subject do token`, `owner do invoice` e decisão de autorização. Por isso, a confiança em divulgação de PII é média, não definitiva.

A atividade evoluiu de reconhecimento sem HTTP 200 em outubro para 3.039 respostas 200 em novembro e 41.829 em dezembro. O crescimento exato do volume diário foi de 48 para 504 e depois 1.463 requisições, indicando automação planejada e escalada. Todos os quatro sites aparecem no conjunto suspeito. No tráfego total, MeliCO lidera volume; no critério de invoices distintos, MeliMX lidera por margem pequena.

O impacto de negócio potencial inclui exposição de dados pessoais de faturamento, fraude e engenharia social, obrigação de avaliação sob LGPD e regulações locais, custo de resposta e perda de confiança. Recomenda-se contenção imediata do IDOR, revogação dos quatro tokens, preservação ampliada, hunting das cinco origens, correlação com identidade/aplicação/banco e decisão conjunta de Incident Response, Legal e Privacy.

2. Escopo e perguntas

O exame cobre apenas o CSV entregue e o endpoint indicado. Busca responder se houve exploração, qual foi a escala, como evoluiu, quais sites aparecem e que evidências adicionais são necessárias. Não cobre outros endpoints, resposta HTTP, cadastro de usuários, ownership de invoices, emissão de tokens, banco de dados ou eventos após 2025-12-31.

3. Preservação e metodologia

O PDF, ZIP e CSV foram identificados por SHA-256. O ZIP foi validado contra path traversal; o CSV foi extraído para área fora do Git e mantido inalterado. A base derivada normaliza o erro `http_staus`, extrai `invoice_id`, `site_id` e `authToken` da URI e interpreta o timestamp no formato real YYYY-DD-MMTHH:MM.

Evidência	SHA-256
PDF da prova	E9CCF7E8459F90019EEEEAA628134D636B6D88E6956283CD563C5DFC6BC6CEFF4
ZIP de logs	E5B14BBE9EEBF3D9A62A89EEA36FA640EC84A5FBD5585B963B6EB7D4A2E0DF54
CSV analisado	DB95EA3855EAAB29BD209FC9876E129EBB6574A6169CB0366B4DDED5E36D94BF

Foram comparadas cardinalidade, distribuição de status, tokens, user agents, referers, sites e séries temporais. País/ASN dos 20 IPs de maior volume foi enriquecido em 2026-08-21 via IPWho. Geolocalização e ASN são contexto atual e não prova de localização histórica ou autoria.

4. Hipóteses

Hipótese	Resultado	Fundamentação
Automação em massa	Sustentada	61.961 requisições; UAs exclusivamente crawler/Scrapy/wget
Reutilização concentrada de token	Sustentada	4 tokens exclusivos compartilhados por 5 origens
Escalada no trimestre	Sustentada	1.488 -> 15.120 -> 45.353 requisições/mês
Potencial entrega de PII	Parcialmente sustentada	44.868 HTTP 200; corpo ausente
Acesso cross-account	Não testável	Sem owner do invoice e subject do token
Atribuição pessoal	Não sustentada	IP/ASN não identifica operador

5. Achados técnicos

5.1 Indicadores principais

Métrica	Resultado
Registros	4.478.619
IPs únicos	5.726
Invoices únicos	10.233
Tokens únicos	35
Sites	4
IPs no cluster automatizado	5
Requisições do cluster	61.961
Invoices tocados pelo cluster	10.181
HTTP 200 do cluster	44.868
Invoices com HTTP 200 no cluster	10.173

Os cinco primeiros IPs têm entre 12.244 e 12.453 requisições, 6.376 a 6.481 invoices e apenas quatro tokens cada. O IP mediano do conjunto total tem 788 requisições, 715 invoices e 31 tokens. Essa inversão entre volume, alcance e baixa diversidade de tokens separa o cluster do tráfego de base.

5.2 Distribuição de status

No conjunto completo, os status são: 200 (785.553), 400 (739.695), 201 (739.226), 304 (736.350), 401 (735.324), 202 (733.981), 408 (4.254) e 406 (4.236). O uso de 201/202 em um GET é atípico e deve ser validado com a aplicação.

No cluster suspeito: 44.868 respostas 200, 3.959 respostas 201, 4.644 respostas 400, 4.236 respostas 406 e 4.254 respostas 408. Outubro contém apenas falhas 400/406/408; novembro mistura 200/201 e falhas; dezembro concentra 41.829 respostas 200. A mudança é compatível com reconhecimento seguido por exploração efetiva, embora exija confirmação com logs de aplicação.

5.3 Tokens, invoices e automação

Os quatro tokens do cluster aparecem somente nos cinco IPs automatizados. Em contraste, os principais tokens do tráfego de base aparecem em 5.721 IPs e 5.001 invoices cada, sinal de que o dataset pode ser sintético ou agregar identidades de forma não realista. A conclusão depende do contraste de UAs, volumes, status e progressão, não do token isolado.

Os UAs suspeitos somam exatamente 61.961 eventos: crawler4j 24.140, Scrappy 24.053 e wget 13.768. Os demais UAs somam 4.416.658 eventos. Não há duplicatas exatas.

5.4 Sites afetados

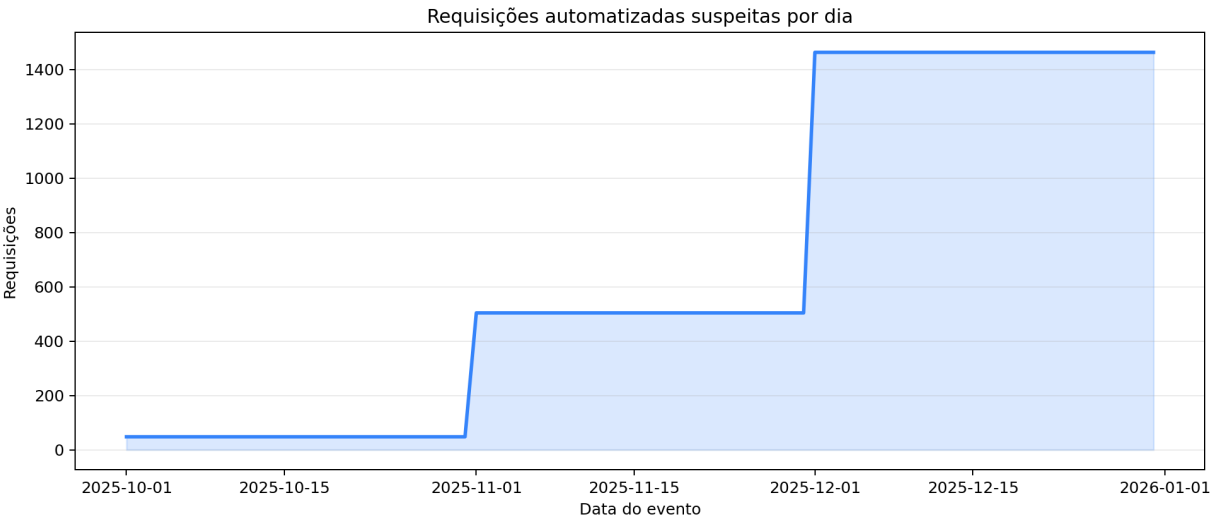
Site	Requisições totais	Invoices únicos	HTTP 200 total	HTTP 200 suspeito	Invoices suspeitos com 200
MeliCO	1.120.465	8.307	196.794	11.189	6.740
MeliMX	1.120.006	8.320	196.673	11.193	6.785
MeliBR	1.119.367	8.314	196.186	11.331	6.770
MeliAR	1.118.781	8.319	195.900	11.155	6.736

MeliCO é o site de maior volume total. MeliMX tem o maior número de invoices distintos no tráfego total e no subconjunto suspeito com HTTP 200. As diferenças são pequenas; operacionalmente, os quatro sites devem ser tratados como afetados.

5.5 Países e ASNs dos top 20

Entre os 20 IPs de maior volume, Estados Unidos somam 67.838 requisições, Argentina 14.698 e Austrália 4.750. Os ASNs de maior volume são AS7303 Telecom Argentina (14.698), AS7922 Comcast (14.446), AS16591 Google Fiber (12.429), AS6128 Optimum (12.426), AS12271 Charter (12.409) e AS11426 Charter (12.244). Os cinco IPs do cluster são dos Estados Unidos, em cinco acessos residenciais distintos. VPN, proxy, NAT e comprometimento de dispositivo continuam possíveis; não há base para atribuição.

6. Linha do tempo



Período	Requisições suspeitas	HTTP 200	Interpretação
Outubro/2025	1.488 (48/dia)	0	Reconhecimento e calibração provável
Novembro/2025	15.120 (504/dia)	3.039	Transição para acesso bem-sucedido
Dezembro/2025	45.353 (1.463/dia)	41.829	Exploração em escala e alta taxa de sucesso

Período	Requisições suspeitas	HTTP 200	Interpretação
2026-01-01	Vulnerabilidade detectada	-	Início do caso fora da janela de logs

7. Gaps de visibilidade

- Sem body, bytes enviados ou campo de PII: não confirma dados efetivamente entregues.
- Sem owner/account do invoice e subject/escopo do token: não prova cross-account.
- Sem request ID, trace ID e decisão de autorização: correlação limitada.
- Timestamp sem timezone e com resolução de minuto: ordem intraminuto e alinhamento externo são incertos.
- Sem X-Forwarded-For, CDN/WAF, device/session e proxy chain: source IP pode não ser origem final.
- Sem emissão, uso, revogação e autenticação de tokens: não distingue token roubado, teste ou conta comprometida.
- Sem logs de aplicação, banco e data access: não confirma consulta e retorno de PII.
- Sem manifesto de coleta e custodiante anterior: cadeia de custódia prévia incompleta.
- A distribuição do dataset é altamente regular e tokens comuns aparecem em milhares de IPs; confirmar se a evidência é produção, amostra ou dado sintético.

Solicitar imediatamente CDN/load balancer/WAF, aplicação, serviço de identidade, gateway de API, auditoria de banco, token lifecycle, response metadata, cadastro de owner do invoice, antifraude e tickets de suporte, todos sob legal hold e com sincronização de relógio documentada.

8. Conclusões e admissibilidade

Há alta confiança de que a vulnerabilidade foi exercitada de forma automatizada e crescente. O alcance máximo observado é 10.181 invoices consultados pelo cluster; o conjunto conservador de potencial divulgação é 10.173 invoices com HTTP 200. A materialidade é alta porque quase todo o universo de invoices presente nos logs aparece no cluster.

Não se conclui autoria, intenção criminosa, titular afetado ou PII efetivamente entregue apenas com esta fonte. O relatório é tecnicamente reproduzível e os arquivos recebidos estão identificados por hash, mas Legal deve completar a cadeia anterior à entrega e correlacionar fontes primárias antes de decisões regulatórias ou notificações.

9. Recomendações priorizadas

0 a 24 horas

1. Corrigir o IDOR com autorização server-side por subject, invoice e site; não confiar em `invoice_id` ou token presente na URL.
2. Revogar os quatro tokens do cluster, remover tokens de query string e exigir rotação/reautenticação.
3. Bloquear ou desafiar temporariamente as cinco origens completas da saída restrita e aplicar rate limit por subject/objeto.
4. Preservar logs correlatos e response metadata sob legal hold; registrar hash, custodiante e acesso.
5. Acionar Incident Response, AppSec, IAM, Billing, Legal e Privacy; iniciar avaliação de obrigação sob LGPD e leis locais sem presumir notificação.

2 a 7 dias

1. Mapear os 10.173 invoices com HTTP 200 para owner, PII potencial e subject do token.

2. Revisar fraude, alteração de dados, engenharia social e suporte associados aos titulares.
3. Executar hunting dos cinco IPs, quatro tokens, três UAs e invoices em todos os endpoints.
4. Implantar alertas para cardinalidade anormal de objetos por subject/IP e para múltiplos tokens em automação.
5. Validar a semântica dos status 201/202/304 no GET e a origem altamente regular do dataset.

30 a 90 dias

1. Centralizar autorização objeto-a-objeto e criar testes negativos de BOLA/IDOR no CI.
2. Registrar subject pseudonimizado, object owner, decisão/política, request/trace ID, response bytes e timezone UTC.
3. Adotar tokens curtos e vinculados a audience/scope; proibir segredos em URL.
4. Criar playbook de PII exposure, métricas de tempo de detecção e exercícios com Legal/Privacy.
5. Monitorar risco residual e comprovar eficácia com testes de regressão e purple team.

10. Agente GenAI

O agente implementa o ciclo planejar -> executar ferramentas -> construir catálogo de evidências -> gerar narrativa -> verificar citações -> revisão humana. Ele usa apenas saídas sanitizadas, exige referências EVID-*, separa observação/inferência/desconhecido e bloqueia afirmação de autoria ou PII confirmada baseada somente em status. Sem modelo configurado, mantém fallback determinístico auditável. A saída do agente é apoio analítico, nunca evidência primária ou decisão automática.

Apêndice - artefatos

Os rankings completos sanitizados estão em `results/public/top_20_ips.csv`, `top_20_ip_enrichment.csv`, `status_by_top_ip.csv`, `top_10_tokens.csv`, `site_impact.csv` e `daily_timeline.csv`. As versões completas são geradas em `results/restricted/` e não são publicadas.